Security and Privacy

Filipa Leite – 202206948

Francisca Macedo – 202205575

2024/2025

— Assignment #2: Privacy Impact Assessment

Index

1. Introduction and Contextualization
2. System Description
   - 2.1 System Overview
   - 2.2 Description of Collected Data
     - 2.2.1 Personality Identifiable Information (PII)
     - 2.2.2 Sensitive Data
   - 2.3 Entities Involved
   - 2.4 Data Flow
3. Initial Risk Assessment´
   - 3.1 Risk Assessment Methodology
     - 3.1.1 Assessment Context
     - 3.1.2 Risk Categorization
     - 3.1.3 Risk Evaluation Scale
   - 3.2 Privacy Risk Assessment
   - 3.3 Privacy Risk Matrix
   - 3.4 Conclusion of Initial Risk Assessment
4. Risk Assessment and Corrective Measures
   - 4.1 Additional Risks and Mitigation Strategies
5. Application of Corrective Measures
6. Conclusion

1. Introduction and Contextualization

Privacy and data protection are crucial in today's world, especially involving and processing personal data. The COP-MODE project collects personal data through smartphones over a week, with the institution managing both data control and processing.

This report focuses on performing a Privacy Impact Assessment (PIA) for the project, identifying privacy risks, evaluating current controls, and proposing corrective measures.

2. System Description

The system analyzed in the context of the COP-MODE project is designed to collect data from a group of users who use smartphones to track and record different types of information over a week. The system collects personally identifiable information (PII) from participants to support research and studies related to mobile technology usage and behavior.

Bellow, we provide an overview of the system's structure, the parties involved, and the type of data being collected.

2.1 System Overview

The COP-MODE system is designed to conduct data collection campaigns through smartphones. Participants use for a week a smartphone where the device gathers data related to app usage, locations, and other behaviors. The collected data is sent to a central server under the control of the data controller (PII controller), with the aim of enabling further research and analysis.

2.2 Description of Collected Data

During the data collection period, we collect Personally Identifiable Information (PII) and Sensitive Data.

2.2.1 Personally Identifiable Information (PII)

Includes the participant's email, which is used as the main point of contact throughout the campaign, allowing the project team to communicate effectively with participants during and after data collection.

2.2.2 Sensitive Data

Includes precise GPS location details to track and analyze participants movement patterns. It also records app usage information, such as which applications are accessed and the amount of time spent on each app.

2.3 Entities Involved

The main entities involved in the COP-MODE project are the participants, who provide personal data during the campaign. We also have the data controller, which is the institution managing the project and deciding how data is going to be processed, and the data processor, who basically carries out the collection and processing tasks under the controller's guidance.
In some situations, third parties may also be involved, such as secure storage providers, but no personal data is shared without participant consent. ´

2.4 Data Flow

The data flow in COP-MODE project flows five stages: collection, transmission, storage, access, and deletion.
During the campaign, participants' smartphones collect data such as location and app usage. This information is securely sent to a central server controlled by the data controller, where it is stored with protective measures. Only authorized personnel can access this data, ensuring compliance with privacy regulations. Once the study ends, the data is either anonymized or deleted, following retention rules.

3. Initial Risk Assessment

3.1 Risk Assessment Methodology

For the initial risk assessment of the COP-MODE project, we used the CNIL Privacy Impact Assessment (PIA) methodology and its associated software tool.

3.1.1 Assessment Context

The assessment was carried out based on a "plain setup" scenario, where the system is implemented without any privacy or security protective measures in place. This approach helps us to identify the inherent risks within the system's architecture, establish an initial risk level, and provide clear justification for subsequent protective measures.

3.1.2 Risk Categorization

Following the CNIL methodology, we evaluated the three primary categories of privacy risks in the COP-MODE project.

The first is illegitimate access to data, which could result in unauthorized individuals gaining access to sensitive information such as participants location data, app usage patterns, and email addresses. This creates the risk of violating participants privacy and the improper use of their personal information.
The second risk is unwanted modification of data, where unauthorized changes could compromise the integrity of the collected information, leading to incorrect analysis or decisions based on altered data.
Finally, the third category relates to data disappearance, involving the loss, destruction, or unavailability of personal data, which could impact both the projects functionality and the rights of data subjects.

3.1.3 Risk Evaluation Scale

Initially, the risks are evaluated without any privacy or security measures applied, showing that the system has inherent vulnerabilities. Both the severity and likelihood of risks are classified as important. This is due to the sensitive nature of the data collected (including location, app usage, and email addresses), where compromise could lead to privacy breaches, unauthorized contact, etc. Without mitigation measures, the system remains exposed to threats such as unauthorized access, data modification through human error, and data loss from system failures, highlighting the necessity of implementing strong security measures.

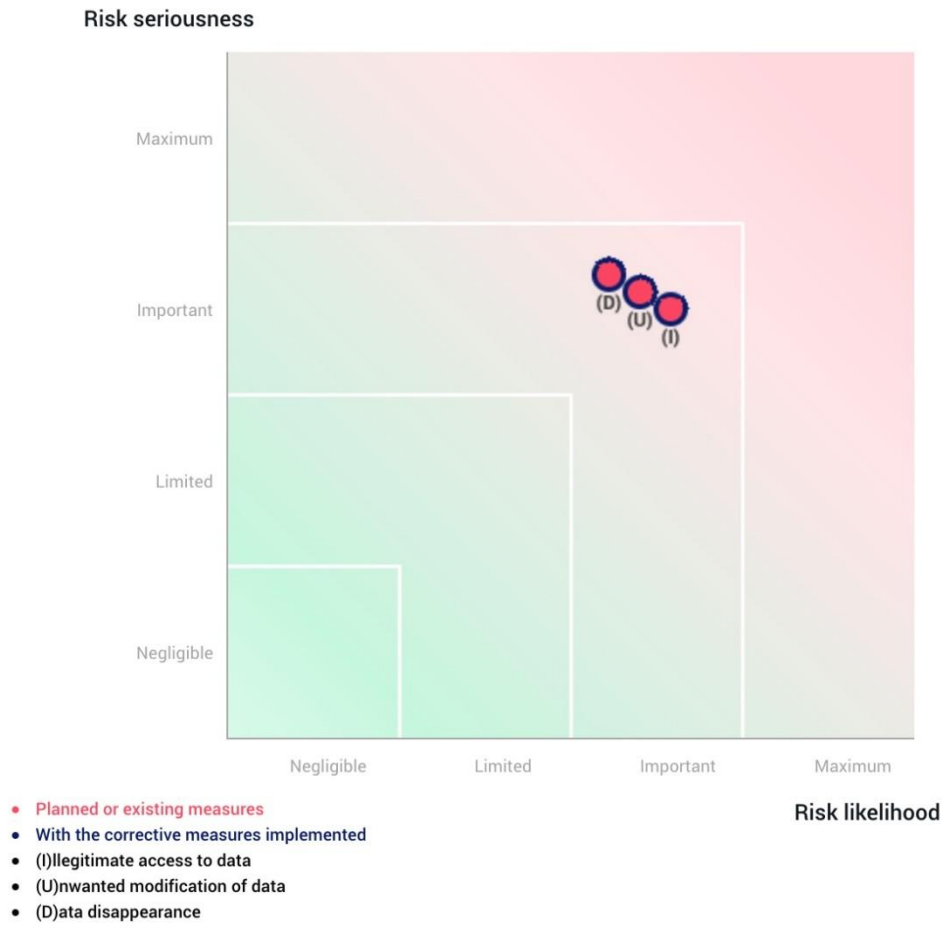
3.2 Privacy Risk Assessment

In terms of illegitimate access, the likelihood is considered important due to vulnerabilities such as exposure to external attackers, malicious applications, unsecured networks, and insider threats. Without encryption or strict access controls, sensitive data like GPS locations, app usage patterns, and personal identifiers are at considerable risk of unauthorized access. Such compromises could result in privacy violations, profiling, and unauthorized tracking of participants.

Regarding the risk of unwanted data modification, the risk is also rated as important. The lack of controls such as integrity checks leaves the system vulnerable to data alteration through device vulnerabilities, transmission failures, or unauthorized interference.

Similarly, the risk of data disappearance is important. Without appropriate safeguards, threats such as system failures, hardware malfunctions, or human error increase the likelihood of data loss.

3.3 Privacy Risk Matrix



The matrix shows that in the current plain setup scenario, all three risk categories are positioned in the critical or high-risk zones. This indicates an unacceptable level of privacy risk for the participants.
The positioning of the risks justifies the need for implementing appropriate corrective measures to mitigate potential threats.

3.4 Conclusion of Initial Risk Assessment

The initial privacy risk assessment reveals significant privacy concerns that require immediate attention. Our analysis demonstrates that the project in is current form, without protective measures, presents unacceptable levels of risk to participants personal data.

4. Risk Assessment and Corrective Measures

Risk	Likelihood	Severity	Mitigation
Non-anonymized Data	High	High	Anonymize sensitive data, encrypt data at rest and in transit, implement strict access control
Non-partitioned Data	Medium	High	Implement data partitioning, separate sensitive data from non-sensitive data, and apply role-based access controls to restrict data access.
No Backups	High	High	Implement regular backup procedures, store backups in secure locations, and ensure backups are tested periodically for integrity.
Failure to Check for Malware	Medium	High	Use software to scan for malware

The risk assessment highlights several significant vulnerabilities with the current setup of the COP-MODE project.
By implementing corrective measures such as anonymizing sensitive data, separating data types, setting up regular backups, and using malware scanning tools, these risks can be minimized.
These steps are extremely necessary to improve data security and ensure privacy standards.

4.1 Additional Risks and Mitigation Strategies

Risk	Mitigation
Data leak through eavesdropping of communications between smartphones and the project server	We should encrypt communications in order to make any intercepted data unusable
Data leak from unauthorized server/data access. Access to the stored data should be limited to authorized users and the server should be accessible remotely, but not exposed/accessible directly to from the outside.	Access control mechanisms and authentication should ensure only authorized personnel can reach the server
Data at rest linkage. The data in the server should not be linkable to an individual by third parties, but the PII collector/processor must still be able to link it to the data in the server	Encrypt sensitive data at rest, ensuring that only the PII collector/processor (and necessary authorized collaborators) have knowledge of the decryption method and key, if required. This ensures that third parties cannot link the data to individuals, while still allowing the PII collector/processor to perform necessary linkage
Sensitive information leakage, in particular the names of the applications that are collected. It is required to know that a given application was used and is the same for the several entries that are collected, but the names of the applications should not be present in the server in raw format.	Control access to the data and encrypt (or pseudonymize) the application names before storage, so that they are not present in raw format on the server

The implementation of the proposed mitigation measures contributes to a reduction in likelihood and the potential impact of each identified risk. Consequently, the overall risk exposure is lower, thereby reinforcing the security of the system and ensuring the confidentiality and protection of the personal data processed within the campaign.

5. Application of Corrective Measures

The COP-MODE project collects and processes sensitive personal data, including continuous geographic location, calendar entries, installed apps with permissions, and nearby device identifiers (Bluetooth and Wi-Fi). These data types present significant privacy risks, such as unauthorized tracking, profiling, and exposure of user's personal data and social connections.
To mitigate these risks, we implemented the following measures:

Encryption, all the sensitive data are encrypted, this ensures that even when a data breach or an interception happens, the information remains protected from unauthorized parties.

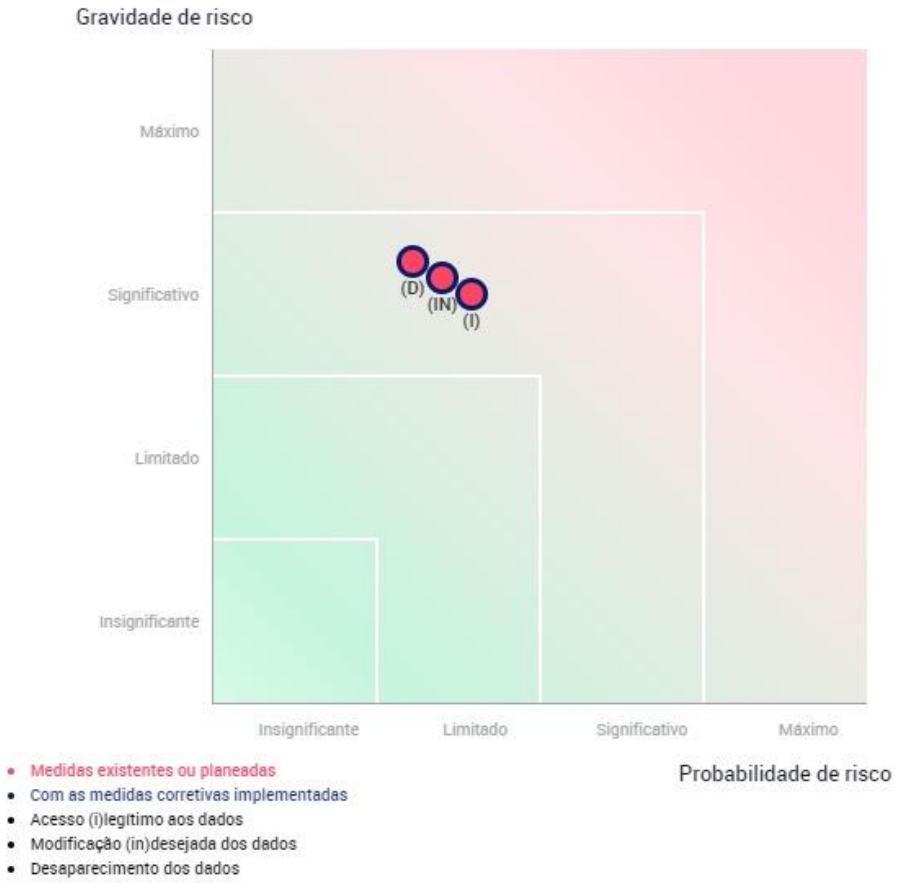
Access Control, Role-based access controls restrict data to approved team members on a need-to-know basis, minimizing internal threats and accidental leaks.

Anonymization and Pseudonymization, this measure minimize the risk of individuals being identified if datasets are leaked or abused.

Data Isolation, different types of sensitive data are stored in separate databases with isolated access controls. This containment prevents cross-linking of data that could amplify privacy risks, such as reconstructing user routines or social networks.

Data Segmentation, this approach also minimizes the impact of potential data loss incidents by limiting their range.

After applying these corrective measures, we did a re-assessment of risks.



The updated Risk Mapping shows a reduction in both likelihood and severity in all three risk categories, meaning that the improved setup ensures that COP-MODE now meets higher standards of data protection/confidentiality and reduces exposure of participants sensitive personal data.

6. Conclusion

In conclusion, the PIA identified significant risks for the COP-MODE project.
We implemented corrective measures, and verified that the risks were greatly reduced. The project with these measures protects the participant data and compliance with privacy standards, ensuring more secure handling of personal information.